School of Computing Sciences

MODULE: CMP-6045B – Developing Secure Software
ASSIGNMENT TITLE: 002/102 – Secure Development Project and Presentation

SET BY: Debbie Taylor Debbie.taylor@uea.ac.uk
CHECKED BY: Eleanor Leist E.leist@uea.ac.uk
VALUE: **70%**

DATE SET: 05 March 2026
DUE DATE: 14 May 2026 15:00 [week 12]
RETURN DATE: 11 June 2026
SUBMISSION METHOD: Blackboard – Live Demo Presentations tba W/C 11 May

Learning outcomes

- Understand the importance of designing software with the security needs of an end user in mind
- Develop a secure and usable website that meets the needs of the user
- Analyse the effectiveness of a range of security methods and tools
- Analyse the evolving threats associated with the internet

Specification

Overview

The aim of this assignment is for your group to code a secure and usable web-based blog system that mitigates, at a minimum, the five most common security vulnerabilities of account enumeration, session hijacking, SQL injection, cross-site scripting and cross-site request forgery.

You will work in the ***same groups as assignment 001***, to code and secure a web-based blog using ***JavaScript*** and ***Node.js,*** with a ***PostgreSQL database***. You will also have to produce a group client flyer (max 2 pages) about your blog's ***key security features.***

The blog system will require registration and login authentication, search functionality, and the ability to add, edit and delete posts. You can use pre-built security libraries, but you must clearly and concisely explain these during your demonstration. You can choose to start with the provided front-end JavaScript template, uploaded to the 002 assessment folder, or you can code your own front-end from outset. However, as this ***second assessment focuses on security*** the front end will only be used to evidence the success of your coded mitigations, therefore, no marks will be allocated for the front-end web development.

There will be weekly formative SCRUM meetings with your client, played by the lab leaders. Each member of your group is expected to attend and engage with this process by discussing ongoing progress and plans for the week ahead. There are marks available for lab attendance and engagement.

To evidence your system's security mitigations, you will attend a live in-person demo in week 12. You will have **a maximum of 15 minutes to demo your working security mitigations, evidence your testing and show your Trello and the key features client flyer *(plus a further* 15-minute Q&A that will cover both group and individual questions*).*** There is no option for the demo to be held remotely, and every group member must attend and engage with the live demo session.

Description
In your groups, you are required to develop a small, secure and usable, web-based blog site that mitigates various security vulnerabilities.

Development Coding of Web-Based Blog:
At a minimum, you should code security mitigations that can defend against the five most common vulnerabilities of:

- Account enumeration
- Session hijacking
- SQL injection
- Cross-site scripting
- Cross-site request forgery

Your ***focus should be on developing the security aspects*** of a web-based blog, rather than web development, as the front-end will only be used to evidence your functioning security mitigations during the week 12 demo. You can choose to start with the front-end JavaScript template, uploaded to the 002 assessment folder, or you can code your own front-end from outset. however, there are no marks allocated for the front-end web development.

To secure your blog you must include hashing, salting and/or peppering, encryption and an additional authentication method to username and password. This could include 2FA, MFA, one time password, graphical password, etc.

The system must not sacrifice usability for functionality, but if your group is able to code more complex functionality, without impacting usability, there will be extra marks available.

Additional marks will also be available for groups that secure their system against other potential vulnerabilities and/or attacks.

You must code your blog-website using ***JavaScript*** and ***Node.js***, with a ***PostgreSQL database.*** Node Express is acceptable, but you cannot use any other frameworks, such as React, and you are restricted to using PostgreSQL as your database. You are welcome to host the blog locally, as you will demonstrate your system from a personal laptop in week 12.

You can also use pre-built security libraries, but you must clearly and concisely explain how they work, what they secure against and exactly how

they provide security protection, during the demo. If you cannot fully explain your library use, your group will not receive any marks for that mitigation. There are, however, extra marks available for coding your own security processes/algorithms.

Each mitigation must remain valid throughout the blog, e.g., you cannot mitigate SQL injection and then break it later when mitigating another vulnerability.

There will be weekly SCRUM meetings, during the lab sessions, with the lab leaders playing the role of the client, to check on progress and engagement. All group members must attend every lab session and engage with this process to achieve individual marks on this section of the mark scheme.

The code you produce must be fully tested, using think-aloud user testing, system unit and security testing. Evidence of these tests (and results) must be recorded via separate test plans and shown during the week 12 live demo. *You must not use generative AI to code this system*.

Engagement will also be monitored via the CMP group work policy. You will be sent a link to an online Engagement Form via Blackboard in week 11. When completing this you should state what percentage of work each group member completed (out of a maximum of 100% across the whole group) and provide a brief critical analysis of each person's contribution and engagement to support the score allocated.

During the Q&A portion of the demo, you will receive both group and individual questions. The individual questions will cover a part of the system that you did not personally code, ensuring that you demonstrate a comprehensive understanding of the entire system. Therefore, it is crucial to familiarise yourself with your groupmates' work, as your individual score will be based on the depth and completeness of your responses.

At the beginning of the Week 6 lab session, you will need to create a new Trello board and invite all members of the teaching team to join. Further details will be available in the Week 6 lab sheet. Additionally, during the Week 7-11 lab sessions, you will receive individual SCRUM marks based on your attendance and participation.

Maximum 2-page Group Client Flyer:
This should discuss the key security features and can include screenshots to help the client visualise and understand your security features. A paper copy should be handed to the markers at the start of the start of your demo.

You can write this client flyer using any document format, such PowerPoint, or Word, however, the content must be clear and accessible to the client, avoiding technical jargon and acronyms and focus on your system's key features. *You must not use generative AI to complete this flyer.*

Deliverables – summative requirements

Live demo (week 12):

- In Week 11, you will be assigned a 30-minute live demonstration slot for Week 12. The first 15 minutes will be dedicated to showcasing all your security mitigations, presenting testing evidence, and displaying your Trello and the group client flyer. The remaining 15 minutes will be used to answer both group and individual questions.
- All group members must attend and actively participate in the live in-person demo. The presentation should be structured to demonstrate the system's functionality, covering both front-end and back-end security measures, including authentication, encryption, hashing and/or salting, and usability.
    - The front-end should demonstrate the security vulnerabilities that have been mitigated or protected against.
    - The back-end must provide evidence of the authentication mechanisms and security coding functions implemented to safeguard the system.
    - Testing should be showcased by presenting relevant templates and Explaining how the results influenced any modifications. You should also discuss and evidence system usability from a user's perspective.
    - The client flyer must be displayed.
    - The Trello board should be shown, along with a discussion on how tasks were distributed among group members.

Please note: The first 15 minutes is dedicated to your demo and you will be stopped at the 15-minute mark, if necessary, as the remaining time is reserved for the group and individual Q&A session. To ensure you cover all required elements within the allotted time, we recommend you practice your demo in advance. Any aspects not demonstrated before the cutoff time will not be assessed.

This is a group assignment so the **group work policy will apply**. You will be required to complete the Engagement Group Report (link to be sent via Blackboard announcement in week 11), stating what percentage of the work each group member completed and providing a brief critical analysis of each person's contribution and engagement to support your score.

Relationship to formative assessment

This assignment builds upon the formative tasks you complete during your weekly lab sessions.

The weekly SCRUM meetings with your client (lab leaders) offer an opportunity to ask questions and clarify the assignment requirements. It is essential that all group members actively participate in this process, to achieve weekly attendance and engagement marks.

Resources

Lecture notes and previous lab sessions are highly relevant to this work. Lab leaders will be playing the part of the client during weekly SCRUM

meetings, so please ask questions if you do not understand something. We reserve the right to not answer a question if it will compromise your learning objective for this module.

- Erickson J., (2008) *Hacking: The art of exploitation*. 2nd edition San Francisco: No Start Press
- OWASP Top 10. Available at https://owasp.org/www-project-top-ten/
- Anderson R. (2008) Security Engineering: A Guide to Building Dependable Distributed Systems, Wiley, available on the author's website (https://www.cl.cam.ac.uk/~rja14/book.html)
- The DBLP bibliography server (https://dblp.org/) is also an excellent resource for most topics and holds data and links for over 4.8 million computing publications.

Handing in procedure

- ***Each group member*** must upload a single zipped copy of the below using the format of `studentID-GroupNumber.zip` e.g. *`10000000-PGT01.zip`*
    - **System code and README document** – the README must explain how to load and run the code.
    - **Group Client Flyer –** PDF of the maximum 2-page client flyer, showing each group member's student number on page 1.
    - **Engagement Group Report** – You will need to fill in the online engagement form. A link will be sent via Blackboard announcement in week 11.

Plagiarism, collusion and contract cheating

The University takes academic integrity very seriously. You must not commit plagiarism, collusion, or contract cheating in your submitted work. Our Policy on Plagiarism, Collusion, and Contract Cheating explains:

- what is meant by the terms 'plagiarism', 'collusion', and 'contract cheating'
- how to avoid plagiarism, collusion, and contract cheating
- using a proof reader
- what will happen if we suspect that you have breached the policy.

It is essential that you read this policy and you undertake (or refresh your memory of) our school's training on this. You can find the policy and related guidance here: https://my.uea.ac.uk/departments/learning-and-teaching/students/academic-cycle/regulations-and-discipline/plagiarism-awareness

The policy allows us to make some rules specific to this assessment. Note that:

In this assessment, you are permitted to work within groups proscribed by the assessment setter. Discussing solutions to tasks *between* groups, or groups otherwise working together to perform the assessed tasks will be considered as a breach of university regulations. Please pay careful attention to the definitions of contract cheating, plagiarism and collusion in the policy and ask your module organiser if you are unsure about anything.

The use of chatGPT (or other Artificial Intelligence applications/websites) to produce any part of your submissions is strictly prohibited. This includes but is not limited to: coding, testing/debugging or documenting code; writing or paraphrasing passages of text; or the generation of bibliographies. Use of these applications in creating submissions is treated as a serious offence by the school and university, and these applications may be considered third-parties with regards to contract cheating.

Marking scheme
See below:

Marksheet – Secure Development Project and Presentation – 70%

Marker Name	Group Number

Marking Details	Mark %	Marking Comments
Demo: Vulnerabilities and Justifications • Account enumeration – max 3 • Session hijacking – max 4 • SQL Injection – max 4 • Cross-site scripting – max 4 • Cross-site request forgery – max 4 • Extra vulnerabilities/mitigations – max 12	31	
Demo: Authentication and Justifications • Database Encryption – max 4 • Hashing, Salting and/or Peppering – max 4 • Extra authentication method – max 8	16	
Demo: Usability/Testing Evidence and Justifications • System usability (incl authentication) – max 4 • Think Aloud User Testing – max 2 • System Unit Testing – max 2 • System Security Testing – max 2	10	
Client Flyer • Key security features – max 6 • Relevant visualisations to support key features – max 4 • Structure and quality of grammar/spelling – max 3	13	
Demo: Quality • Content – max 2 • Delivery and Structure – max 2 • Question Answering (Group) – max 4 • Question Answering (Individual) - max 10 • Trello – max 2	20	
SCRUM Meeting Engagement (weeks 7-11) • Attendance and engagement in labs – Max 2 per week	10	